SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

CO2-AT2-Vulnerability Assessment Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.no	192311098	**Name of the Student**	B.Hari Sai

Co2: Identify common network attacks and analyze threat intelligence sources and data collection techniques.

Code of Conduct:

I **B.Hari Sai/192311098** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student :B.Hari Sai

Q1. Explain the common types of network attacks: malware, phishing, DoS and DDoS. Give one example and one preventive measure for each. (10 marks)

A network attack is an attempt to gain unauthorized access to a computer system, steal confidential information, damage data, or interrupt network services. Attackers may target individual users, organizations, or entire networks. Four common types of network attacks are malware, phishing, Denial of Service (DoS), and Distributed Denial of Service (DDoS).

1. Malware

Malware means malicious software designed to harm a device, steal information, spy on users, or gain unauthorized access. Common forms include:

- **Virus:** Attaches itself to a legitimate file or program and spreads when the infected file is run.
- **Worm:** Replicates itself and spreads across networks, often by exploiting security weaknesses.
- **Trojan horse:** Pretends to be useful or legitimate software but performs harmful actions after installation.
- **Ransomware:** Encrypts files or locks a system and demands payment to restore access.
- **Spyware:** Secretly monitors activity and may collect browsing details, credentials, or other private information.

Example: ransomware infects a company computer and encrypts important business documents. Prevention: install reputable, updated endpoint protection, apply security patches, keep offline or protected backups, and avoid unknown downloads and attachments.

2. Phishing

Phishing is a social-engineering attack in which an attacker uses deceptive emails, text messages, phone calls, or fake websites to trick people into revealing passwords, banking details, or other sensitive information. Messages often create urgency by claiming that an account will be blocked or a payment must be confirmed.

Example: a user receives an email that appears to come from a bank and follows a fake login link, entering their password on the attacker's website. Prevention: train users to recognize suspicious messages, verify the sender and website address, use email filtering and multi-factor authentication (MFA), and avoid opening unexpected attachments or links.

3. Denial of Service (DoS)
A DoS attack attempts to make a computer, website, or network unavailable by overwhelming it with excessive requests or traffic. In a typical DoS attack, the traffic comes from one main source, making it comparatively easier to trace than a distributed attack.

Example: one compromised computer repeatedly sends requests to a small business website until the server cannot respond to legitimate visitors. Prevention: configure firewalls, apply rate limits, monitor traffic, and use suitable intrusion-prevention and server-protection measures.

4. Distributed Denial of Service (DDoS)
A DDoS attack has the same goal as a DoS attack, but the traffic comes from many devices at once. Attackers often control a botnet—a group of infected computers, routers, or Internet of Things (IoT) devices—to generate a large volume of traffic. The distributed sources make blocking the attack more difficult.

Example: a botnet sends huge amounts of traffic to an online shopping website, preventing customers from accessing it. Prevention: use a DDoS protection service, content delivery network (CDN), traffic scrubbing, rate limiting, and support from the internet service provider.

Conclusion: malware harms or spies on systems, phishing manipulates users, and DoS/DDoS attacks interrupt service availability. Security updates, user awareness, layered defenses, backups, and traffic monitoring help reduce these risks.

Q2. What is a Man-in-the-Middle (MitM) attack? Describe how it works and the techniques used to carry it out, and list the countermeasures. (8 marks)
A Man-in-the-Middle (MitM) attack occurs when an attacker secretly positions themselves between two parties that are communicating, such as a user and a website. The attacker may observe, steal, or alter information while each party believes the communication is direct and trustworthy. MitM attacks can expose passwords, session tokens, personal information, or financial details.

How a MitM attack works
1. The attacker finds a way to enter or influence the communication path between the victim and the intended service.
2. The victim sends data, such as a login request, through a connection that the attacker can observe or manipulate.
3. The attacker may read the information, change selected messages, or attempt to steal session details.

4. The attacker forwards traffic to the intended destination so that the victim and service may not immediately notice the interception.

Common techniques

- **ARP poisoning:** On a local network, the attacker sends misleading Address Resolution Protocol (ARP) messages to associate the attacker's device with another device's IP address. Traffic may then be redirected through the attacker.
- **Rogue Wi-Fi access point:** The attacker creates an unauthorized wireless hotspot with a convincing name, hoping users will connect and send data through it.
- **DNS spoofing:** False Domain Name System (DNS) responses direct a user to an unintended or fraudulent destination instead of the legitimate website.
- **Session hijacking:** An attacker obtains or reuses a valid session token to act as an already authenticated user.

Example: a person connects to a fake public Wi-Fi hotspot and visits a poorly secured website. The attacker may observe unencrypted information or attempt to redirect the user to a fake page.

Countermeasures

- Use HTTPS/TLS for websites and applications, and never ignore certificate warnings.
- Validate certificates correctly so that the client can confirm it is communicating with the legitimate server.
- Enable HTTP Strict Transport Security (HSTS) on websites to require secure HTTPS connections.
- Use a trusted VPN when accessing sensitive services over public Wi-Fi, while still checking the destination certificate.
- Avoid unknown Wi-Fi hotspots and use strong security settings on wireless networks.
- Use dynamic ARP inspection and other switch protections where supported to reduce ARP-poisoning risks.
- Protect session cookies with Secure and HttpOnly attributes, use appropriate SameSite settings, and expire sessions safely.

Conclusion: MitM attacks exploit weak or untrusted communication paths. Encryption, certificate validation, secure network configuration, and careful user behavior are essential defenses.

Q3. Differentiate between spoofing and sniffing. Describe the types of spoofing and explain how sniffing can be detected or prevented. (8 marks)

Spoofing and sniffing are different network security concepts. Spoofing involves falsifying an identity or source information to make communication appear to come

from a trusted source. Sniffing involves capturing and examining packets travelling across a network. Spoofing is commonly used to deceive systems or users, while sniffing is used to observe traffic and may expose data when it is not encrypted.

Difference between spoofing and sniffing

Aspect	Spoofing	Sniffing
Meaning	Forging an identity or address.	Capturing and inspecting network packets.
Main purpose	Impersonation, deception, or bypassing trust controls.	Observing communication and possibly collecting information.
Method	Alters or falsifies identifying information.	Uses packet-capture software or network monitoring equipment.
Example	A forged email sender address.	Capturing unencrypted traffic on a shared network.

Types of spoofing

- **IP spoofing:** The source IP address in a packet is forged to make the traffic appear to originate from another system. It may be used in reflection attacks or to hide the true source.
- **MAC spoofing:** A device changes the MAC address it presents on a local network, potentially impersonating another device or bypassing weak address-based controls.
- **Email spoofing:** The sender information in an email is falsified to make the message appear to come from a trusted person or organization.
- **DNS spoofing:** False DNS information causes a domain name to resolve to an incorrect address, potentially sending users to a fraudulent site.

How sniffing can be detected or prevented

- Encrypt data in transit using HTTPS/TLS, SSH, and secure VPN connections. Encryption makes captured packets much less useful to an attacker.
- Use switched networks and secure switch configurations to reduce unnecessary exposure of traffic to other devices.
- Enable port security and network access controls to restrict unauthorized devices and connections.
- Monitor network traffic with approved network-monitoring tools and intrusion detection/prevention systems (IDS/IPS) to identify suspicious behavior.

- Restrict administrative access and packet-capture tools to authorized staff, and audit privileged activity.
- Use anti-spoofing filters, ingress/egress filtering, and email authentication controls such as SPF, DKIM, and DMARC where appropriate.

Example: if an attacker captures packets on a shared network, HTTPS prevents them from easily reading the contents of a user's login session. Passive sniffing can be difficult to detect directly, so encryption and strong network controls are especially important.

Q4. Define vulnerability assessment. Explain its steps and describe the contents of a good vulnerability assessment report. (8 marks)

A vulnerability assessment is a systematic process of identifying, examining, and prioritizing security weaknesses in computers, servers, applications, and networks. Its purpose is to help an organization understand where it is exposed and decide which weaknesses should be corrected first. Testing should be authorized and performed within an agreed scope.

Steps in vulnerability assessment

5. Asset identification and scope: identify the systems, applications, IP addresses, and network segments to be assessed. Confirm permission and testing boundaries.
6. Scanning: use approved tools such as Nessus or OpenVAS to search for known vulnerabilities, missing patches, insecure services, and configuration weaknesses.
7. Validation and analysis: manually review important results, remove duplicates, and check for false positives so that findings are reliable.
8. Risk rating: evaluate severity, exploitability, exposure, asset importance, and potential business impact. CVSS scores can help describe technical severity.
9. Remediation planning: recommend actions such as patching, configuration changes, removing unnecessary services, or adding compensating controls.
10. Reporting and retesting: document the findings, assign priorities, and rescan or retest after fixes to confirm that the weaknesses have been addressed.

Contents of a good vulnerability assessment report

- Executive summary: a brief overview of the assessment, major risks, and overall security posture.
- Scope and methodology: systems tested, dates, tools used, assumptions, and any limitations.
- Detailed findings: vulnerability description, affected assets, evidence, and relevant technical details.

- Identifiers and severity: CVE IDs where applicable, CVSS scores, and clear severity ratings such as Critical, High, Medium, or Low.
- Risk and business impact: explain what an attacker could potentially do and how the issue could affect confidentiality, integrity, or availability.
- Prioritized remediation: specific recommended fixes, suggested urgency, and responsible teams or owners.
- Retest status: indicate whether each issue is open, fixed, or requires further verification.

Vulnerability assessment vs. penetration testing

A vulnerability assessment mainly identifies and prioritizes weaknesses across a defined set of assets. Penetration testing goes further by attempting controlled exploitation of selected weaknesses to demonstrate how an attacker might gain access or cause impact. Both activities are useful and should be performed with proper authorization.

Conclusion: a useful assessment report does more than list scanner results; it explains the evidence, real risk, and practical steps needed to reduce exposure.

Q5. What is Open-Source Intelligence (OSINT)? Discuss the common threat data sources and the techniques used to collect threat data. (8 marks)

Open-Source Intelligence (OSINT) is the process of collecting, checking, and analyzing information from publicly available sources to produce useful intelligence. In cybersecurity, OSINT helps security teams learn about exposed systems, malicious domains, known vulnerabilities, phishing campaigns, and emerging threats. “Open source” here means publicly accessible information, not necessarily software with an open-source license.

Common threat data sources

- **WHOIS and domain records:** Registration information may provide details about a domain, its registrar, or relevant dates. Privacy services may hide some information.
- **DNS records and certificate-transparency logs:** These can help analysts discover domain relationships, hostnames, and certificates associated with internet-facing services.
- **Internet-exposure search engines:** Services such as Shodan index publicly reachable devices and services, helping authorized teams understand their own exposed assets.
- **Social media, news, blogs, and forums:** These sources can reveal phishing reports, scam campaigns, attacker claims, and public discussion of new threats.

- **Code repositories and issue trackers:** Public repositories may reveal vulnerable code, exposed credentials, or security advisories; findings should be verified before action.
- **CVE and NVD databases:** The Common Vulnerabilities and Exposures (CVE) system and National Vulnerability Database (NVD) provide information about publicly known software vulnerabilities.
- **Commercial and internal sources:** Commercial threat-intelligence providers supply curated data, while internal logs, endpoint alerts, incident records, and honeypots provide organization-specific evidence.

Techniques used to collect threat data

- Passive collection: examine public websites, records, advisories, and reports without directly interacting with the target system.
- Search-engine research: use focused queries to locate security advisories, leaked information, public discussions, and references to suspicious indicators.
- Permitted web scraping: collect publicly available pages at a reasonable rate while respecting applicable laws and website terms.
- DNS and domain lookups: review DNS records, domain relationships, registration details, and certificate information to understand infrastructure.
- Threat-feed and database review: gather known malicious IP addresses, domains, file hashes, and vulnerability details from trusted sources.
- Log and honeypot analysis: review internal security logs and controlled decoy systems to identify scanning, attempted access, or suspicious behavior.
- Correlation and validation: compare information from multiple sources, check its date and reliability, and add context before treating it as a confirmed threat.

Legal and ethical considerations

OSINT should use lawful sources and authorized methods. Analysts must respect privacy, data-protection requirements, website terms, and organizational policies. Public availability does not automatically make every use lawful or ethical. Do not access private systems or accounts without permission, and protect any sensitive information discovered.

Conclusion: OSINT combines public records, security databases, online discussions, and technical lookups to build a clearer picture of threats. Verification and context are necessary because public information can be incomplete, outdated, or misleading.

Q6. What are Indicators of Compromise (IoCs)? Explain the types of IoCs and describe how threat feeds help organizations improve their defense. (8 marks)

Indicators of Compromise (IoCs) are observable pieces of evidence that suggest a computer, account, or network may have been compromised or involved in malicious activity. Security teams use IoCs to detect possible attacks, investigate incidents, search historical logs, and support containment. An IoC is a clue rather than absolute proof, so it should be assessed with surrounding context.

Types of IoCs

- **File hashes:** Cryptographic hashes such as SHA-256 can identify a known malicious file. A hash may change if the file changes, so hash matching alone may miss modified samples.
- **IP addresses:** An IP address may be linked to a command-and-control server, scanning activity, or malicious hosting. Shared hosting and reassigned addresses can create false positives.
- **Domains and URLs:** Domains may be used for phishing, malware delivery, or command-and-control communication. A URL can identify a specific suspicious page or download location.
- **File and system artifacts:** Unexpected files, suspicious registry keys, startup entries, scheduled tasks, or unusual processes may indicate malware installation or persistence.
- **Email indicators:** Suspicious sender addresses, message headers, subjects, attachment hashes, and links can help identify phishing campaigns.
- **Network and behavioral indicators:** Unusual outbound connections, unexpected data transfers, repeated failed logins, or communication with known malicious infrastructure can indicate suspicious activity.

How threat feeds improve organizational defense

A threat-intelligence feed provides regularly updated information about threats and their indicators. Feeds may come from open-source communities, commercial security vendors, government advisories, industry-sharing groups, or an organization's own investigations.

- Early warning: feeds can inform defenders about newly observed malicious domains, IP addresses, file hashes, and attack campaigns.
- Automated detection: SIEM, EDR, IDS/IPS, DNS security, and firewall systems can compare events against relevant indicators and generate alerts or block selected activity.
- Faster incident response: analysts can search logs for matching indicators to determine whether an organization may have been affected.

- Threat hunting: teams can proactively search endpoints and network records for evidence of known attacker activity.
- Information sharing: STIX is a common format for representing structured threat information, while TAXII supports exchanging threat intelligence between systems.

Limitations and best practices

Threat feeds can contain false positives, stale indicators, incomplete information, or indicators that are relevant only to a particular context. Some IP addresses and domains are shared by legitimate and malicious services. Organizations should review the source and confidence of each indicator, consider how recent it is, correlate it with local evidence, and update feeds regularly. Blocking should be proportionate to the risk and should not disrupt legitimate services without review.

Conclusion: IoCs provide useful clues for detecting and investigating attacks, while threat feeds help distribute those clues quickly. Their effectiveness depends on timely updates, reliable sources, and careful validation.